SPOTIFY'S DATA & AI GOVERNANCE PROJECT

3. *Data & AI Governance Implementation* Plan

Annexes

> *Nicolas Pichon --- AIA RNCP 38777 / BC01 / Step 3 / Annexes / v15 --- 2026/10/15.*

3.A. Couverture des enjeux identifiés en évaluation

#	Enjeu	Dispositions du plan d'implémentation
E1	Décompartimenter les données	Modèle *CoE* ([D3, §3.3], standard commun porté par CDO/DGC + responsabilité départementale préservée) ; *Collibra* comme catalogue commun opéré par *DS*/*DO* ([D3, §3.4]) ; Test du rattachement fonctionnel du *DS* en pilote phase 1, généralisation en phases 2&3 (§3.F, §3.G.2)
E2	Maîtriser la qualité des données	*Soda Core*, étendu au contrôle courant (*DS*) et aux données d'entraînement (*MO*) ; Test en pilote sur le moteur de recommandation (§3.F.1) ; généralisation à tous les départements en phases 2/3/4 (§3.G.2)
E3	Maîtriser la conformité réglementaire dans un contexte multi-juridictionnel	*TrustArc* comme socle unique, couvrant nativement les DSAR conformément à [R11, Q4] ([D3, §3.4]) ; Population initiale du *RoPA* testée sur le périmètre du pilote , sous réserve de classification préalable (§3.F.1, §3.F.2) ; modèle *CoE* conciliant standard central et déclinaison locale ([D3, §3.3]) ; généralisation prioritaire sur *Marketing* en phase 3, périmètre le plus exposé au risque réglementaire (§3.G.2)
E4	Garantir la vie privée et l'usage éthique des données	*TrustArc* seul (consentement, notification de violation, droits des utilisateurs P7) ([D3, §3.4]) ; viabilité du déploiement incrémental à valider séparément avant Phase 3, hors périmètre du pilote (§3.G.3)
E5	Gouverner spécifiquement les données *IA*	*MLflow*, *DVC*, *AIF360*, *AIX360* opérés par MO/MRM ([D3, §3.4]) ; circuit de gouvernance proportionné au niveau d'impact du modèle - classification unique à la création, approbation de déploiement héritée à chaque version, contrôle a posteriori et reclassification en cas rares ([D21-Annexes, §2.1.A]) ; calibration des seuils en pilote (§3.F.2, §3.F.4, §3.G.1)
E6	Accompagner la montée en compétences *data*	Volet formation et accompagnement au changement (§3.F.9), reconduit à chaque phase de généralisation (§3.G.2)

3.B. Les modèles d'organisation de la gouvernance *data*

3.B.1. Les principaux modèles

Modèles courants

Les modèles d'organisation de la gouvernance *data* les plus connus sont les suivants (cf. [R7]) :

Modèle	Avantages	Limites
Centralisé	Simple à implémenter, priorisation facile.	Déconnexion business/data ; les besoins métier finissent par dépasser la capacité de l'équipe centrale.
Embarqué	Agilité, proximité business/data, spécialisation	Absence de source unique de vérité, création de silos, difficile à piloter pour les métiers sans bagage technique.
Centre of Excellence (**CoE**)	Combine les avantages des deux modèles précédents	Nécessite une couche de coordination supplémentaire qui n'est pas adaptée aux petites/moyennes structures.

Structure générale du modèle *CoE*

Dans la littérature concernant la gouvernance des données, *CoE* est généralement décrit comme un modèle **hub-and-spoke** (*centre-et-antennes*) construit sur une base de trois composantes :

- Le **hub** (centre) : une petite équipe d'experts qui fixe les standards, construit les briques réutilisables (méthodologie, outillage, formation) et porte la plateforme technique partagée entre toutes les unités de métier ;
- Les **spokes** (antennes) : des rôles embarqués dans chaque unité de métier qui exécutent avec la connaissance du domaine et l'agilité locale.
- Le **conseil de gouvernance**, réuni périodiquement, qui arbitre les priorités et les exceptions.

Les principes du modèle sont résumés par la formule : *gouverner et outiller au centre, exécuter à la périphérie* (« *govern and enable at the center, execute at the edge* »). Le hub porte à la fois l'autorité de standards et la plateforme technique partagée, les deux entités étant logées au même niveau organisationnel.

3.B.2. Analyse de l'adéquation du modèle *centralisé* (au cas *Spotify*)

Le modèle *centralisé* isolerait la fonction *data* dans une organisation où les départements se sont déjà appropriée la donnée ([D1] relève que la littératie *data* et l'usage analytique sont bien implantés dans les départements et portés par des équipes de métier autonomes), et rendrait plus difficile la résolution de l'enjeu de décompartimentation des données (E1) en retirant aux *Data Owners* l'autorité de proximité dont ils ont besoin.

3.B.3. Analyse de l'adéquation du modèle *embarqué*

Le modèle *embarqué* reconduirait par construction l'enjeu de décompartimentation des données à l'origine des silos (E1). Il empêcherait également de régler l'enjeu de conformité multi-juridictionnelle (E3) en dispersant les ressources juridiques à travers les départements et les marchés.

3.B.4. Analyse de l'adéquation du modèle *hybride*

Le modèle *CoE* formalise *a posteriori* l'organigramme défini en [D22], à quelques nuances près, confirmant qu'il est le seul modèle d'organisation parmi ls trois modèles les plus courants qui réponde simultanément aux enjeux de décompartimentation (*E1*), de conformité multi-juridictionnelle globale / locale (*E3*) et de gouvernance d'IA (*E5*).

L'implémentation [D22] s'écarte du modèle canonique sur deux points : 1) en maintenant l'infrastructure et les compétences techniques dans le département *Engineering* ; 2) en séparant l'autorité de conformité (représentée par les rôles *DPO* et *Legal Team*) de l'autorité de gouvernance (représentée par les rôles *CDO* et *DGC*).

Nuance #1. L'infrastructure et les compétences techniques sont maintenues dans le département *Engineering*.

Le modèle générique *CoE* place la plateforme technique partagée au sein du hub, au même niveau que l'autorité de standards. Ce n'est pas le cas de l'organigramme [D22] : les *Data Custodians* (qui assurent le rôle technique transversal : gestion technique et sécurisée du stockage pour l'ensemble des domaines) sont rattachés organiquement au département *Engineering* (qui n'est pas vu comme une entité élevée au niveau du *CDO/DGC* mais comme un département de métier pair, au meme niveau que les autres : *Marketing*, *Product Development*, etc.).

Nuance #2. Les autorités de *conformité* et de *gouvernance des données* sont séparées et indépendantes.

Le modèle générique *CoE* se structure normalement autour d'un unique hub générique et ne distingue pas les autorités de gouvernance et de conformité. Dans l'implémentation [D22], au contraire, les deux autorités sont rattachées directement au *CEO* et ne sont pas

hiérarchisées entre elles. L'autorité de gouvernance des données (standards, qualité, stratégie) est représentée par les rôles *CDO* et *Data Governance Committee*. L'autorité de conformité est représentée par les rôles *DPO* et *Legal Team*.

Surcoût du modèle *CoE*. Le *CoE* est difficile à adapter aux petites et moyennes structures du fait de la charge que représente la mise en place d'une mécanisme supplémentaire de coordination entre centre et départements. Mais *Spotify* n'est pas une petite structure : 450 millions d'utilisateurs actifs (2023, [R2]), couverture de plus 180 pays, plusieurs départements autonomes, prise en charge de régimes réglementaires hétérogènes. À cette échelle, la charge de coordination supplémentaire n'est pas un coût additionnel mais une nécessité fonctionnelle, que seul ce modèle est structurellement conçu pour absorber.

3.C. Justification de la sélection d'outils

3.C.1. Principes

Principe #1. On reprendre la liste de recommandations [R8], on la complète de solutions alternatives *open-sources*, et on couvre la liste des besoins fonctionnels avec les outils sélectionnés, en favorisant les solutions open-sources.

Principe #2. L'économie réalisée sur le coût des licenses d'une solution open-source est contre-balancée, en général, par le surcoût de la prise en charge de l'hébergement et de l'exploitation. Dans le cas de *Spotify*, on estime que la capacité d'ingénierie interne (documentée dans [R2]) permettra de maintenir le coût d'une solution open-source à la hauteur du coût des solutions propriétaires équivalentes.

Principe #3. On admet que les enjeux porteurs d'un risque réglementaire chiffrable (E3, E4) nécessitent des garanties de service contractuelles que justifient la tarification éventuellement couteuse et opaque des solutions commerciales. Les enjeux organisationnels (E1) et opérationnels (E2, E5) ne portent que des coûts de défaillance interne (dégradation de service, retard, mauvaise qualité) sans comparaison avec le coût d'une amende.

3.C.2. Catalogage des données

> *Solution retenue: OpenMetadata (inventaire technique et lineage) + Collibra (glossaires, workflows).*

Atlas vs. OpenMetadata. *Apache Atlas* [R8] est une solution techniquement solide et open source, mais historiquement ancré dans l'écosystème Or l'infrastructure de Spotify présentée dans [R2] (data lakes, bases relationnelles, stockage cloud) ne comporte aucun ancrage explicite sur *Hadoop*. A l'inverse, *OpenMetadata* couvre nativement les technologies de l'infrastructure .
Spotify via ses connecteurs (*BigQuery*, *Snowflake*, *S3*, *Iceberg*, *Power BI*).

Alation vs. Collibra. Compte tenu de l'enjeu réglementaire E3, les solutions open-sources comportent un risque disproportionné sur les fonctions de gouvernance (workflows, glossaires, journaux d'audit) du fait de l'absence de garantie de service contractuelle. *Alation* et *Collibra* [R8] sont des solutions commerciales de catalogage qui intègrent toutes les deux des fonctions de gouvernance avancées. *Collibra* est retenue car elle propose un socle de gouvernance prédéfini plus solide.

En particulier, il existe un connecteur officiel et bien documenté de *OpenMetadata* vers *Collibra*. Il permet de 1) synchroniser les glossaires *Collibra* vers *OpenMetadata*, 2) faire correspondre les actifs *Collibra* aux entités déjà existantes dans *OpenMetadata*.

3.C.3. Qualité des données

> *Solution retenue : Soda Core (contrôle courant + contrôle des datasets d'entrainement) avec solution de replis TestGen (en cas de retrait de Soda Core) et/ou Cuallee (en cas d'insuffisance des contrôles ML avec Soda Core).*

Talend [R8] est une suite globale d'ETL qui intègre des fonctions de contrôle de qualité mais qui ne propose pas ces fonctions comme des produits autonomes. On ne peut pas retenir cette solution puisque *Spotify* possède déjà une infrastructure ETL.

Informatica [R8] est une suite complète mais hétérogène de gestion de données (qualité, catalogage, gouvernance, etc.). On ne retient pas cette solution pour plusieurs raisons : 1) une fragmentation architecturale interne qui imposerait une charge de réconciliation supplémentaire au *Data Custodian* - sans bénéfice pour l'enjeu de désilotage (E1) ; 2) la production et à la maintenance des règles de qualité nécessite des compétences techniques qui ne correspondent pas au profil du *Data Steward* ; 3) le coût opaque de la solution combiné à des délais de déploiement relativement longs (1 à 2 semestres) est disproportionné au regard du niveau de risque des enjeux opérationnels (E2, E5).

Ataccama [R8] est une plateforme unifiée de confiance des données, construite sur une architecture unifiée et cohérente, et qui couvre dans les fonctions de gouvernance, de contrôle de qualité, de gestion des données de référence et des données maîtresses, et d'observabilité. Cependant, en fin de compte, cette solution reste un produit commercial à coût élevé et opaque, non justifié pour les enjeux opérationnels (E2, E5).

Soda est une solution de contrôle de qualité des données composée d'un noyau open source (*Soda Core*) pour les vérifications déclaratives et d'une couche commerciale (*Soda Cloud*) pour le monitoring et les alertes. *Soda Core* est retenu pour le contrôle de qualité des données courantes (E2) et des données d'entraînement (E5). Ses connecteurs couvrent l'ensemble des sources citées dans [R2] (entrepôts cloud, bases relationnelles).

Cuallee est une bibliothèque Python de validation de la qualité des données appliquée à des *data-frames*. Elle couvre les data-frames *Snowflake*/*Snowpark*, *PySpark* et *pandas*. Ses principales fonctionnalités sont : les contrôles courants d'intégrité, les contrôles de dates et d'horodatages, les tests statistiques, les contrôles personnalisés, via un constructeur d'expressions SQL, les contrôles globaux (inter-colonnes), la validation des colonnes à normes ISO.

DataOps TestGen de *DataKitchen* (désigné implement comme "*TestGen*" dans cet exercice) est un outil open source de qualité des données qui génère des tests de façon algorithmique à partir du *profilage* (*data profiling*). Il couvre cinq tâches : profilage des données,

screening et revue d'hygiène d'un nouveau jeu de données, génération algorithmique de tests de validation, tests en production à chaque rafraîchissement, et surveillance périodique des anomalies. Il ne génère pas de tests de code applicatif.

Réserve #1. Il est possible qu'à l'issue du projet pilote, on constate un besoin de contrôles statistiques plus spécifiquement conçus pour l'apprentissage automatique que ceux qui sont permis par les vérifications déclaratives de *Soda Core*. Dans ce cas, une solution de repli possible est *Cuallee*, une bibliothèque de contrôle de qualité spécialisée dans les données d'apprentissage automatique et conçue pour rester indépendante du moteur de calcul (*Pandas*, *Snowflake*, *DuckDB*, *Spark*).

Réserve #2. La feuille de route des produits *Soda* s'oriente de plus en plus vers l'offre commerciale *Soda Cloud*, ce qui laisse les utilisateurs du noyau open source avec une parité de fonctionnalités plus lente et un engagement à long terme moins net. *TestGen* est identifié comme une solution de repli à évaluer si cette orientation se confirme. Sa maturité d'écosystème (connecteurs vers la stack *Spotify*, communauté) devra être vérifiée au préalable.

3.C.4. Conformité réglementaire

> *Solution retenue: TrustArc (fonctions RoPA/DPIA/NB + DSAR).*
>
> *Glossaire :*
> *- RoPA : Record of Processing Activities (RGPD, art. 30),*
> *- DPIA : Data Protection Impact Assessment (RGPD, art. 35),*
> *- BN : Breach Notification (RGPD, art. 33 & 34),*
> - *DSAR : Data Subject Access Request (RGPD/CCPA).

Aucune alternative *open-source* ne couvre les fonctions *RoPA*, *DPIA*, *BN* et *DSAR* avec une garantie de service adaptée au risque financier documenté dans [R2]. Par ailleurs, [R11, Q4] confirme que la couverture des fonctions *DSAR* (gestion des demandes d'accès, de modification ou de suppression des données utilisateur) est attendue nativement du dispositif de conformité central.

VeraSafe [R8] est cabinet de conseil et de services managés (*DPO* externalisé, représentation légale, audits) et non une solution logicielle.

DataGuard [R8] est une plateforme de *conformité et de gestion des risques* (ISO 27001, TISAX, NIS2, SOC 2, RGPD), avec RoPA, DPIA, gestion du consentement et des demandes d'accès et de suppression. Cet outil est explicitement positionné comme une solution particulièrement bien adaptée aux *PME*, incluant dans son abonnement un accès à des *DPO* et des juristes certifiés inclus dans l'abonnement. Rejeté d'office du fait que *Spotify* n'est pas positionné sur cette échelle.

OneTrust et *TrustArc* [R8] sont toutes les deux des plateformes logicielles, la première couvre un périmètre complet de *GRC* (*Governance*, *Risk*, *Compliance*), la seconde étant plus spécialisée dans la protection des données personnelles (consentement, droits des utilisateurs, notification de violation, RoPA, DPIA). Les deux solutions sont équivalentes au regard des enjeux de conformité de *Spotify* (E3, E4).

Les avantages de *TrustArc* sur *OneTrust* :

- Une *automatisation multi-juridictionnelle explicite* (un enjeu que [D1] identifie comme le point le plus difficile de l'enjeu E3) - la déclinaison simultanée de *RGPD* (UE), *CCPA* (Californie), *PDPA* (Singapour) et des régimes locaux.
- Une meilleure *facilité d'usage* et une meilleure *qualité du support* qui touchent toutes les deux directement le rôle *DPO* (opérateur quotidien de cet outil).

3.C.5. Sécurisation des données et des accès

> *Solution retenue: Wazuh (SIEM) + OpenBao (chiffrement & clés).*

DataGuard [R8] est une plateforme de *conformité et de gestion des risques* et n'est pas un *outil de chiffrement ou de détection d'incidents* : il est reclassé avec les outils de gestion de conformité en §3.C.4.

Vormetric [R8] (racheté par *Thales*) est une solution de chiffrement des données au repos et de gestion centralisée des clés, pensée pour les environnements d'entreprise hybrides/multi-cloud. La tarification est commerciale classique, avec licence propriétaire. Rejeté au profit d'*OpenBao*, qui propose les mêmes services (gestion des clés), sans coût de licence, et avec les avantages de l'open-sources, avec la nuance qu'on vient de préciser sur son mode de fonctionnement réel (gestion des clés + chiffrement à l'appel via *Transit*, pas un chiffrement transparent automatique).

Splunk [R8] est une plateforme *SIEM* (*Security Information and Event Management*) commerciale. La tarification se fait au volume de données ingérées, pouvant atteindre plusieurs centaines de milliers de dollars par an à l'échelle d'un flux quotidien de 50 Go. Rejetée au profit de *Wazuh* qui combine SIEM, détection d'intrusion et rapports de conformité sans coût de licence.

OpenBao est une solution open-source de chiffrement et de gestion des secrets qui propose les mêmes services que *Vormetric* à une nuance près : le chiffrement n'est ni *transparent* ni *automatique*, comme avec *Vormetric*, mais doit se faire à la demande via une API du module *Transit Secrets Engine*.

Wazuh est une plateforme de sécurité open-source qui combine deux fonctions habituellement séparées :

- *SIEM* (*Security Information and Event Management*) : collecte, corrélation et analyse de journaux provenant de sources multiples (systèmes, réseau, cloud), génération d'alertes et de rapports.
- *XDR* (*Extended Detection and Response*) : déploiement d'agent sur chaque terminal (endpoint), détection comportementale, réponse automatisée.

3.C.6. Gouvernance des modèles

> *Solution retenue: MLFlow (catalogage & lineage)+ DVC (versionage) + AIF360 (biais)+ AIX360 (explicabilité).*

Le périmètre fonctionnel de ces outils est spécifique aux enjeux de gouvernance des modèles (et absent des recommandations d'outils [R8]) et composé des quatre exigences du principe stratégique de *éthique et gouvernance de l'IA* (*P8*) [D21] : traçabilité, détection de biais, approbation, explicabilité.

MLflow trace l'état d'un modèle mais n'implémente pas nativement les circuits d'approbation prévu par l'organisation [D22]. La gouvernance des modèles reste un *processus* non-automatisé, porté par les rôles *Model Owner*, *Model Risk Manager* et *Data Governance Committee*. Les circuits d'approbation, différenciés selon le niveau d'impact du modèle, sont détaillés dans l'annexe §3.E.

DVC (*Data Version Control*) est un système open-source de versionnage de données, de modèles et d'expériences ML, sous licence Apache 2.0. Les métadonnées *DVC* sont conservées sous *Git* et servent de pointeurs. Les données elles-mêmes sont envoyées vers un site de stockage distant, indépendant du système *DVC* (S3, Azure, GCS, SSH, HDFS, HTTP).

AIF360 (*AI Fairness 360*) est une bibliothèque open-source Python qui fournit des métriques d'équité pour des jeux de données et des modèles, des explications de ces métriques, et des algorithmes de réduction des biais. Projet d'*IBM Research* transféré à *Linux Foundation* en juillet 2020.

Contenu annoncé. Environ 70 métriques (parité statistique, égalité des chances, impact disproportionné…) et 10 algorithmes d'atténuation, parmi lesquels la repondération, le pré-traitement optimisé, le *debiasing* adversarial et le post-traitement à égalité de chances.

AIX360 (*AI Explainability 360*) est une boîte à outils open-source, créée par *IBM Research* et donnée à *Linux Foundation*, pour comprendre et expliquer des modèles ML et des jeux de données (tabulaires, texte, images, séries temporelles).

3.D. Sécurisation des données d'entrainement et des modèles

Le tableau ci-dessous retrace la cartographie complète des données d'entrainement et des modèles, de la captation des données originales au déploiement des modèle en production, en identifiant les mécanismes de sécurisation à chaque étape. L'objectif est d'être capable de mettre en place les infrastructures de sécurisation le plus tôt possible, dès le démarrage du projet pilote, et de les développer tout au long de la généralisation.

On considère que les processus *0A* (ingestion brute) et *0B* (ETL) sont déjà en place chez *Spotify*. Le plan d'implémentation ne construit pas ces processus mais vérifie leur sécurisation et anticipe les corrections en cas de défaillance.

#	Processus	Description	Outil	Acteurs	Sécurisation
0A	*Captation*	Chaîne d'ingestion des données brutes	*(acquis, pré-existant)*	*DC*	Vérifier le chiffrement des données en transit (TLS) ; *DC* audite l'existant et prépare les corrections de faille
0B	*ETL*	Chaîne de transformation/structuration	*(acquis, pré-existant)*	*DC*	Vérifier la sécurisation du pipeline (restriction des accès) ; *DC* audite comme en *0A*
01	Stockage initial	Dépôt sur support durable crypté (*S3* et équivalents)	*(acquis, pré-existant)*	*DC*	Vérifier cryptage et contrôle des accès ; Suspendre pilote sur constat de faille ; Collecte des profils et des droits d'accès, et centralisation avec *OpenBao* ; Génération et gestion des clés avec *OpenBao*
02	Classification	Détection automatique de la classe PII puis validation de gouvernance	*OpenMetadata* (détection) → *Collibra* (validation)	*DS* (validation)	Détermine le niveau de protection des processus suivants
				DPO (cas ambigus)	
03	Découverte technique	Inventaire des actifs (schémas, localisation)	*OpenMetadata*	*DC*	*RBAC* natif + sync. *SSO* confirmés ; Configuration et sync. des groupes non vérifiés
04	Lineage technique	Traçabilité des flux entre tables/pipelines	*OpenMetadata*	*DC*	Idem
05	Gouvernance / glossaire	Définitions métier, workflows d'approbation	*Collibra*	*DS* (fonctionnel *CDO*)	Idem
				DO	
06	RoPA	Registre des traitements de données personnelles	*TrustArc*	*DPO*	*RBAC* natif confirmé ; Sync. SSO non confirmée
				Legal	
07	Qualité courante	Contrôle des données du domaine (E2)	*Soda Core*	*DS*	Hérite du chiffrement au repos
08	Construction des features	Calcul des variables d'entrée du modèle	*(acquis, pré-existant)*	*MO*	Hérite du chiffrement au repos
09	Qualité des features	Contrôle des variables calculées	*Soda Core*	*DS*	Idem
				MO	
10	Stockage des features	Dépôt dans le magasin des features (feature store)	*(acquis, pré-existant)*	*DC*	Vérifier les capacités de sécurisation de l'infrastructure présumée ; Même actions qu'en *01*
11	Construction du dataset	Assemblage, répartition entraînement/validation	-	*MO*	Hérite du chiffrement au repos
12	Qualité du dataset d'entraînement	Contrôle spécifique au jeu ML (E5)	*Soda Core*	*DS*	Idem
				MO	

#	Processus	Description	Outil	Acteurs	Sécurisation
13	Versionnage du dataset	Snapshot restaurable, historique	*DVC*	*MO*	Même backend chiffré qu'en *01*
14	Entraînement du modèle	Exécution, paramètres, métriques	*MLflow*	*MO*	*RBAC* natif présumé, non vérifié
15	Classification de l'impact	A la création du modèle dans le registre	*MLflow* (registre)	*MO* (Responsible)	Procédurale (cf. RACI)
				MRM (Accountable)	
16	Porte d'évaluation	Performance vs. modèle en production, biais, explicabilité - produits ensemble à chaque version	*MLflow*, *AIF360*, *AIX360*	*MO* (production)	Hérite du contexte d'exécution ; RBAC non vérifié
				MRM (revue)	
17	Approbation de déploiement	Selon le palier fixé en 15, sur la base des preuves de 16	-	Selon palier	Procédurale
18	Surveillance continue	Détection d'événements, transversale aux proc. 1-17	*Wazuh*	*DC*	Fonction de surveillance, pas de chiffrement (déjà couvert)
19	Contrôle a posteriori	Échantillonnage (modèles à impact faible uniquement)	-	*MRM*	Procédurale
20	Reclassification	Si changement substantiel ou détection en audit	*MLflow* (registre)	*MO* (Consulted)	Procédurale
				MRM (Accountable)	

> *Glossaire :*
> *- RBAC = Role-Based Access Control (contrôle d'accès basé sur les rôles),*
> *- ABAC = Attribute-Based Access Control (contrôle d'accès basé sur les attributs),*
> *- SSO = Single Sign-On (authentification unique),*
> *- PII = Personally Identifiable Information (données à caractère personnel - DCP).*

Sécurisation non couvertes/non vérifiés.

- Classification préalable des données (processus 02) :
  - dispositif à construire malgré son insertion dans la séquence (cf. §3.F.2/6) ;
- *Features store* (processus 10) :
  - infrastructure présumée, non vérifiée ;
- *RBAC* et/ou synchronisation *SSO* natifs des outils (processus 02-16) :
  - fonctionnalité présumée, non vérifiée ;

3.E. Calculabilité des niveaux d'impact des modèles

Les niveaux d'impact (fort, modéré, faible) et leurs critères sont définis dans [D21-Annexes, §2.1.A.1] ; les circuits d'approbation des déploiements correspondants dans [D21-Annexes, §2.1.A.3] ; la distinction entre classification, approbation et reclassification dans [D21-Annexes, §2.1.A.4] ; les responsabilités (*RACI*) dans [D22-Annexes, §2.2.C]. La présente section ne porte que sur la calculabilité des critères : chacun est soit calculé automatiquement, soit déclaré par le *Model Owner*.

Niveau	Critère	Calculabilité	Outil source
fort	Portée majoritaire	Calculé automatiquement	*MLflow* (métadonnées)
	Exposition art. 22 RGPD (décision individuelle automatisée)	Calculé automatiquement (*)	*OpenMetadata* / *Collibra* (lineage)
	Exposition art. 9 RGPD (données personnelles)	Calculé automatiquement	*OpenMetadata* / *Collibra* (lineage)
	Décision peu réversible	Déclaratif (*Model Owner*)	-
	Fonctionnalité principale du produit (recommandation, personnalisation)	Déclaratif (*Model Owner*)	-
modéré	Portée partielle (cohorte, marché, A/B test)	Calculé	-
	Décision réversible sous délai court	Déclaratif	-
faible	Modèle auxiliaire, sans exposition directe à l'utilisateur final, aucun critère de fort impact rempli	Par défaut, si aucun seuil automatique n'est franchi	-

> (*) Sauf pour la mesure de l'*effet significatif* (déclaré).

3.F. Plan pilote détaillé

3.F.1 Périmètre et justification

> **Périmètre retenu :**
>
> **Les modèles et données d'entraînement du moteur de recommandation (*) au sein du département *Product Development*.**
>
> (*) Le moteur de recommandation est interprété comme un *système*, c'est-à-dire qu'il est potentiellement composé de différents modèles de ML/IA, intégrés entre eux.

Ce périmètre permet de tester simultanément plusieurs enjeux majeurs [D1] ainsi que l'ensemble des mécanismes organisationnels encore non éprouvés en conditions réelles :

Mécanismes	Sources	Enjeux	#
Rattachement fonctionnel du *DS* au *CDO*	[D22]	Décompartimenter les données	E1
Outillage *Soda Core* (contrôle courant & données d'entraînement) - exécuté par *DS* & *MO*	[D3, §3.4]	Maîtriser la qualité des données	E2
Fonctionnement *MO* / *MRM* et circuit de classification/approbation des modèles	[D21-Annexes, §2.1.A], [D22-Annexes, §2.2.C]	Gouverner spécifiquement les données IA	E5
Configuration initiale du glossaire *Collibra* et du RoPA *TrustArc* - limité au périmètre du pilote avant généralisation	aucune source antérieure	Viabilité du déploiement incrémental des outils à portée organisationnelle	E1, E3

Les enjeux de la conformité multi-juridictionnelle (E3) et la vie privée (E4) ne sont pas dans le périmètre principal du pilote. La conformité *RGPD* ne sera pas atteinte avant le déploiement complet de la plateforme (voir les phases de généralisation) car un enregistrement *RoPA* n'est pas conforme *RGPD* tant qu'il ne couvre pas l'ensemble des traitements de l'entreprise.

3.F.2. Objectifs du pilote

Le pilote doit répondre aux points suivants :

1. Valider le rattachement fonctionnel des *Data Stewards* au *CDO* sur un cas réel de décompartimentation (E1).
2. Mesurer la charge d'ingénierie (*Engineering overhead*) réelle portée par les *Data Custodians*.
3. Classifier les modèles testés selon leur niveaux d'impact, tels que définis en [D21-Annexes, §2.1.A.1], puis éprouver le circuit d'approbation correspondant sur des versions successives des modèles.
4. Trancher les points de vigilance techniques identifiés lors de la sélection des outils :
   - Le module qualité natif d'*OpenMetadata* peut-il absorber une partie du périmètre fonctionnel de *Soda Core*?
   - *Soda Core* couvre-t-il tous les contrôles statistiques attendus sur les données d'entraînement (E5) ?
   - Quelle charge de réglage (IAM, règles de détection, tableaux de bord) *Wazuh* et *OpenBao* transfèrent-ils réellement aux *Data Custodians* ?
   - Le connecteur *Collibra*/*OpenMetadata* fonctionne-t-il comme documenté, et quelle fréquence de synchronisation est-elle nécessaire pour couvrir les délais réglementaires [D21, §2.1.4] (délai de 72 h) ?
   - La synchronisation de groupes via SSO (confirmée pour *OpenMetadata* et *Collibra*, non documentée pour *TrustArc*) route-t-elle effectivement les personnes vers les profils d'accès ?
5. Valider la viabilité du déploiement incrémental de *Collibra* (glossaire, workflows) et de *TrustArc* (registre des traitements, *RoPA*), dans la limite du périmètre pilote.
6. Vérifier que la population du *RoPA* dispose d'une classification préalable des données traitées (sensibilité, catégorie de données personnelles).
7. Conduire la migration de sécurisation du stockage initial du périmètre pilote : régénération des secrets concernés, collecte exhaustive des profils et des droits d'accès existants, redéfinition de ces droits via *OpenBao* (module *AWS Secrets Engine*) et l'annuaire d'entreprise partagé.

3.F.3 Équipe et rôles du pilote

Rôle dans le pilote	Rôle	Responsabilité
PPM (Pilot Project Manager)	Rattaché au CDO	Coordination générale, reporting au DGC
Référent qualité du domaine	DS (Product Development)	Exécution du contrôle qualité (Soda Core), test du double rattachement, population du glossaire Collibra scopé au périmètre PD

Rôle dans le pilote	Rôle	Responsabilité
Responsable du modèle recommandation	MO	Exploitation de MLflow, déclenchement des contrôles AIF360, proposition de classification ([D21-Annexes, §2.1.A.4])
Contrôle indépendant	MRM	Revue AIX360/AIF360, validation de la classification, préparation du dossier d'approbation
Autorité métier	DO (Product Managers)	Arbitrage sur les décisions relevant du domaine
Déploiement technique	DC (Engineering)	Déploiement et réglage d'OpenMetadata, Wazuh, OpenBao ; migration de sécurisation du stockage initial (régénération des secrets, collecte et redéfinition des droits d'accès, §3.F.2 point 7) ; suivi de l'Engineering overhead
Conformité	DPO, Legal Team	Population initiale du RoPA (TrustArc) scopée au périmètre PD, sous réserve de la classification préalable des données traitées (§3.F.2, point 6)

3.F.4 Calendrier et jalons

Jalon	Repère	Semaine	Actions	Porteur
01 (x)	A	S1	Lancement du pilote et confirmation de l'existence d'un annuaire d'entreprise central apte à l'intégration SAML/OIDC	PPM, DC
02 (x)	A	S1-S3	Sécurisation des infrastructures préexistantes (captation, ETL, feature store) ; re-génération des secrets et collecte des profils du stockage initial	DC
03 (x)	A	S3-S4	Vérification directe, auprès de l'éditeur, des capacités SSO et de synchronisation de groupes de TrustArc	DPO, Legal Team
04 (x)	A	S4-S5	Vérification du RBAC natif de MLflow, AIF360, AIX360 et Wazuh	DC, MO, MRM
05 (x)	A	S5-S6	Test d'intégration bout-en-bout : un utilisateur test rattaché à un groupe de l'annuaire central obtient les droits attendus dans OpenMetadata, Collibra et TrustArc, ainsi qu'un identifiant AWS dynamique via OpenBao	DC
06 (x)	A	S7	Revue de la phase de sécurisation : décision de poursuite ou de suspension du pilote sur la base des résultats des jalons 01 à 05	PPM, DGC
07.1	B	S8-S11	Déploiement technique (OpenMetadata, DVC, Soda Core, MLflow, AIF360, AIX360, Wazuh, OpenBao)	DC
07.2	B	S8-S17	Population initiale du RoPA (TrustArc) scopée au périmètre PD	DPO, Legal Team
08.1	C	S12	Vérification du recouvrement entre Soda Core et le module qualité natif d'OpenMetadata	DC
08.2	C	S12	Population initiale du glossaire Collibra scopée au périmètre PD	DS
09	C	S13	Vérification du fonctionnement du connecteur Collibra-OpenMetadata	DC
10.1	D	S14	Classification initiale du modèle testé selon le niveau d'impact	MO, MRM
10.2	D	S14-S17	Exécution en conditions réelles : contrôle qualité courant et données d'entraînement, entraînement et évaluation du modèle	DS, MO
11	E	S16	Vérification technique intermédiaire : premiers résultats Soda Core sur le périmètre pilote	DS
12	E	S17	Revue intermédiaire : premiers résultats d'Engineering overhead et d'adoption des standards	PPM
13	F	S18	Premier passage du circuit d'approbation de déploiement correspondant au niveau classé au Jalon 10.1	MRM, DGC selon niveau
14	G	S19	Consolidation des indicateurs et recueil structuré des retours des parties prenantes	Toute l'équipe
15	G	S20	Revue de synthèse	PPM
16	G	S21	Revue finale et clôture du pilote	DGC

> *(x) : Phase de sécurisation.*

3.F.5 Livrables attendus

- Rapport de qualité des données du périmètre pilote
  - résultats Soda Core, couvrant à la fois le contrôle courant et les données d'entraînement.
- Rapport de validation du circuit de classification et d'approbation des modèles :

    - dossier de classification (Jalon 10.1) puis premier dossier d'approbation de déploiement documenté de bout en bout, avec délai constaté.
- Estimation de la charge d'ingénierie pour les outils opérés par les Data Custodians :
    - temps d'ingénierie uniquement, hors coûts d'infrastructure et de maintenance pluriannuelle, hors périmètre du pilote.
- Note de recouvrement technique :
    - décision sur le chevauchement Soda Core/OpenMetadata,
    - et sur l'adéquation de Soda Core pour les contrôles E5 (repli Cuallee si besoin, §3.C).
- Note de synchronisation catalogage :
    - vérification du fonctionnement du connecteur Collibra-OpenMetadata et calibration de sa fréquence au regard des délais réglementaires ([D21, §2.1.4]).
- Note de contrôle d'accès :
    - vérification que les groupes créés dans le fournisseur d'identité d'entreprise correspondent à la taxonomie de rôles définie en [D22], et que chaque outil (RBAC confirmé pour OpenMetadata, Collibra et TrustArc) les traduit correctement en permissions internes - synchronisation de groupes via SSO à valider spécifiquement pour TrustArc, non documentée contrairement aux deux autres outils.
- Rapport de migration de sécurisation :
    - secrets régénérés, profils et droits d'accès existants collectés puis redéfinis via OpenBao (AWS Secrets Engine, §3.C.5) et l'annuaire d'entreprise partagé, avec relevé des accès orphelins éventuellement découverts lors de la collecte.
- Rapport de déploiement initial :
    - glossaire *Collibra* et population initiale du *RoPA* scopés au périmètre *Product Development*, avec évaluation de la viabilité du déploiement incrémental avant extension aux phases suivantes (§3.G.2).
- Retours des parties prenantes du département pilote (*DS*, *MO*, *DO*).
- Rapport d'évaluation du double rattachement *Data Steward* :
    - indicateurs quantitatifs et lecture combinée avec le critère de §3.G.1 (§3.F.6).

3.F.6 Indicateurs de performance (KPIs)

Les indicateurs du pilote sont adossés aux niveaux de maturité *DMAT* utilisés en [D1]/[R1], pour rester mesurables dans la même échelle que le diagnostic initial.

Dimension [D1]	**Niveau init.**	**Cible pilote**	**Cible moyen terme [D21, §2.1.7]**
Data Governance	1	2, sur périmètre pilote uniquement	3, à l'échelle de l'organisation
Data Quality	1	2	3
Analytics & BI (volet *Gouvernance IA*)	2	3, sur le sous-critère *gouvernance des modèles* [R1, Q55-Q57]	3

Un pilote de 21 semaines mené sur un seul périmètre ne doit pas viser le niveau 3 fixé comme objectif global, l'ambition du pilote étant simplement de démontrer la trajectoire.

Méthode de mesure. Pour rester proportionné à la durée du pilote, la re-cotation ne porte que sur les sous-questions DMAT déjà mappées à chaque dimension en [D1-Annexes, §1.A] - pas l'intégralité du questionnaire - et seulement sur le périmètre pilote plutôt que sur l'ensemble de l'organisation.

Dimension [D1]	**Porteur**	**Jalons**	**Instrument de mesure**
Data Governance	*PPM* (auto-évaluation), validation DGC	#16	Re-cotation de Q1-Q6, Q10-Q13 [R1] contre les définitions textuelles du DMAT, restreinte au périmètre pilote
Data Quality	Data Steward (production), PPM (consolidation)	#12 (premier calcul), #16 (score final)	Re-cotation de Q36-Q39 [R1], sur la base des journaux d'exécution Soda Core (règles exécutées, anomalies détectées et résolues, couverture du nettoyage à l'entrée)
Analytics & BI (volet *Gouvernance IA*)	Model Owner (dossier), Model Risk Manager (validation)	#12 (premiers artefacts), #16 (score final)	Re-cotation de Q55-Q57 [R1], sur la base du dossier de classification, des résultats AIF360/AIX360 et du dossier d'approbation ([D21-Annexes, §2.1.A.4])

> *Légende : PPM = Pilot Project Manager.*

La validation du DGC sur le score final (Jalon 16) donne à la re-cotation une légitimité au-delà de la simple auto-évaluation - cohérent avec son rôle d'arbitrage transversal déjà établi dans la matrice RACI [D22-Annexes, §2.2.C], où il n'est jamais *Responsible* d'une

exécution mais *Accountable* sur les décisions de portée générale. C'est ce score validé qui alimente la décision de généralisation (§3.G.1).

Nature de l'exercice. La re-cotation reste un jugement qualitatif, de même nature que l'évaluation initiale [D1] : les niveaux du DMAT [R1] sont des descriptions textuelles, pas des seuils calculables automatiquement, et leur application exige une interprétation humaine. La validation DGC réduit le risque de biais d'auto-évaluation, mais ne rend pas le jugement objectif - deux personnes de bonne foi peuvent observer les mêmes faits différemment. Ce que le pilote améliore n'est donc pas la nature du jugement, mais la matière sur laquelle il s'exerce : au lieu d'interpréter un texte narratif écrit a posteriori ([R2]), il interprète des artefacts opérationnels produits en direct (logs Soda Core, horodatages de workflow Collibra, dossiers de classification, [D21-Annexes, §2.1.A.4]). Chaque score attribué doit être ancré à une preuve explicitement citée - l'artefact précis et sa date - plutôt qu'à une impression générale, pour rester vérifiable et contestable.

Ce tableau couvre les indicateurs de maturité globaux du pilote ; les indicateurs spécifiques à l'évaluation du double rattachement des Data Stewards (E1) font l'objet d'une procédure dédiée en §3.F.6.

Évaluation du double rattachement du Data Steward

Le critère retenu en §3.G.1 pour ce mécanisme - absence de conflit d'autorité rapporté - ne mesure que l'absence de dysfonctionnement, pas la valeur que le double rattachement est censé produire [D22] : l'alignement effectif sur le standard commun porté par le CDO, et le maintien de l'autonomie métier du département. Cette section instrumente ces deux effets.

Effets positifs attendus du rattachement fonctionnel au CDO

1. **Adoption réelle des standards centraux** - le DS applique les standards du CDO dans ses vérifications quotidiennes plutôt que de construire ses propres règles ad hoc, ce qui reproduirait à petite échelle le problème que le rattachement doit résoudre (E1).
2. **Propagation effective des mises à jour de méthodologie** - une évolution de standard publiée par le CDO se retrouve appliquée dans le département sans réécriture locale complète.
3. **Recours effectif à la ligne fonctionnelle comme ressource** - le DS sollicite le CDO en cas d'ambiguïté plutôt que de trancher unilatéralement, signe que le canal fonctionnel est utilisé et non simplement nominal.
4. **Cohérence terminologique avec le glossaire commun** - les définitions et métadonnées produites dans le département correspondent au glossaire Collibra plutôt que de créer des définitions parallèles.
5. **Autonomie décisionnelle départementale non dégradée** (contrepoids nécessaire) - les décisions strictement métier restent prises sans blocage ni attente de validation centrale, faute de quoi le mécanisme dériverait vers le modèle centralisé explicitement écarté (§3.B.2).

Indicateurs et méthode de mesure

Trois des cinq indicateurs sont capturés nativement par les fils de discussion et les workflows de stewardship déjà intégrés à Collibra ([D3, §3.4]), sans outil ni journal supplémentaire - un choix qui limite la mesure aux échanges déjà rattachés à une finalité de gouvernance légitime, plutôt que d'étendre la capture à des canaux qui n'ont jamais eu vocation à être tracés à cette fin.

Indicateur	Définition	Méthode de mesure	Source
Taux d'adoption des standards CDO	Part des vérifications qualité du DS héritées d'un standard central plutôt que créées localement sans validation	Revue de la configuration Soda Core du domaine pilote (checks.yml) : proportion de règles taguées « standard CDO » vs « spécifique domaine »	DC
Délai de propagation d'une mise à jour	Temps écoulé entre la publication d'une évolution de standard par le CDO et son application effective dans le domaine pilote	Horodatage natif des étapes du workflow de révision/approbation Collibra (proposition → révision → publication)	PPM (extraction Collibra)
Fréquence de sollicitation fonctionnelle	Nombre d'échanges DS → CDO (questions, validations, arbitrages) sur la durée du pilote	Comptage des commentaires et fils de discussion initiés par le DS sur les termes et actifs sous responsabilité CDO (Collibra)	DS (extraction Collibra)
Cohérence terminologique	Taux de correspondance exacte entre les définitions produites localement et le glossaire Collibra	Comparaison native au glossaire commun, sans échantillonnage externe	DC, DS
Autonomie départementale préservée	Part des décisions strictement métier prises sans blocage ni attente de validation CDO	Registre structuré minimal des décisions du DO/DS (hors Collibra, car ces décisions ne sont pas rattachées à un terme ou un actif de glossaire), avec motif et délai si validation externe sollicitée	DO

Limite de périmètre : les fils de discussion Collibra ne capturent que les échanges rattachés à un terme ou un actif - une clarification échangée par un autre canal (hors Collibra) n'y apparaît pas. Ce n'est pas une lacune de mesure mais une conséquence du principe de minimisation retenu : seule la donnée déjà collectée pour la finalité de gouvernance déclarée est réutilisée pour cette évaluation.

Calendrier de collecte

Ces effets sont cumulatifs et suivis en continu, à la différence des autres tests du pilote qui reposent sur un jalon ponctuel unique :

- **Jalon 01** : mise en place du seul registre structuré minimal (décisions du DO) - aucun journal supplémentaire à créer pour les sollicitations fonctionnelles, déjà capturées par Collibra.
- **Jalon 10.2** : alimentation continue du registre DO ; extraction de la configuration Soda Core et des données Collibra (commentaires, workflows) en fin de période.
- **Jalon 12** : premier calcul des cinq indicateurs, ajustement possible si un déséquilibre apparaît - par exemple, des sollicitations fonctionnelles proches de zéro signaleraient que le canal n'est pas utilisé, pas qu'il est superflu.
- **Jalon 16** : synthèse consolidée, intégrée à la collecte qualitative de §3.F.10.

Lecture combinée avec le critère de §3.G.1. Le critère négatif (absence de conflit rapporté) reste nécessaire mais devient insuffisant seul : un pilote pourrait afficher zéro conflit simplement parce que le DS n'utilise jamais le canal fonctionnel, masquant un échec silencieux plutôt qu'un succès. Les cinq indicateurs ci-dessus transforment un critère d'échec en preuve de fonctionnement réel, avec l'indicateur d'autonomie comme garde-fou contre une dérive de centralisation de fait.

3.F.8. Gestion des risques

Deux catégories de risques s'ajoutent aux risques opérationnels déjà identifiés, propres à la nouvelle phase de sécurisation (Jalons 01 à 06) : des risques de **suspension sans repli** (le pilote ne peut pas se poursuivre en l'état) et des risques de **débordement du planning** (le jalon prend plus de temps que prévu, sans remettre en cause la poursuite du pilote). Les deux sont signalés explicitement plutôt que noyés dans le reste du tableau.

Risques de suspension du projet (sans repli)

Risque	Probabilité	Impact	Mitigation
Absence d'un annuaire d'entreprise central apte à l'intégration SAML/OIDC (Jalon 01), condition de tout le dispositif RBAC/SSO du plan	Faible à moyenne	Suspension totale, sans repli	Ce prérequis devient un chantier d'infrastructure séparé, hors calendrier du pilote ; aucune poursuite possible tant qu'il n'est pas livré
Défaut de sécurisation non corrigeable dans le délai imparti sur une infrastructure préexistante (Jalon 02)	Faible	Suspension si le défaut n'est pas corrigé avant le Jalon 06	Repli possible uniquement si le défaut est circonscrit à un périmètre isolable du reste du stockage ; sinon, suspension le temps de la correction

Risques de débordement du planning (jalons les plus difficiles à tenir dans le délai imparti)

Risque	Probabilité	Impact	Mitigation
Délai de réponse de TrustArc sur ses capacités SSO/synchronisation de groupes (Jalon 03), hors du contrôle du projet	Moyenne	Débordement du Jalon 03, sans repli sur le délai lui-même	En l'absence de réponse dans le délai, gestion manuelle temporaire des accès TrustArc, documentée comme dérogation, plutôt que d'attendre indéfiniment
Échec du test d'intégration bout-en-bout (Jalon 05), sans marge prévue pour une seconde itération	Moyenne	Débordement du Jalon 06, retardant tout le reste du calendrier	Identifier précisément le maillon défaillant (annuaire, outil, ou mapping de groupes) avant de corriger, plutôt que de re-tester l'ensemble de la chaîne à l'aveugle
Compression de la phase d'exécution en conditions réelles (Jalon 10.2, 4 semaines - la plus courte de toutes les versions de calendrier envisagées)	Moyenne	Fiabilité réduite des indicateurs produits sur cette période (qualité, double rattachement, classification)	Envisager un rallongement ponctuel si les premiers résultats du Jalon 11 s'avèrent insuffisamment stables, plutôt que de clôturer sur des données fragiles

Autres risques opérationnels

Risque	Probabilité	Impact	Mitigation
Charge Data Custodians sous-estimée	Élevée	Élevé	Suivi hebdomadaire du temps passé, arbitrage possible au Jalon 12 ; si la charge d'exploitation d'OpenMetadata s'avère trop lourde en auto-hébergement, bascule possible vers l'offre managée Collate (SLA, support dédié) plutôt qu'un changement d'outil

Risque	Probabilité	Impact	Mitigation
Collecte incomplète des profils et droits d'accès existants lors de la migration de sécurisation (Jalon 02) : un accès oublié devient un accès orphelin après la bascule vers OpenBao	Moyenne	Élevé	Recoupement systématique entre l'inventaire collecté et les journaux d'accès réels du support avant redéfinition des droits ; ne pas clôturer la migration tant qu'un écart subsiste
Soda Core insuffisant pour les contrôles statistiques E5	Moyenne	Moyen	Vérification dès le Jalon 08.1, confirmée au Jalon 11, solution de repli : bascule vers Cuallee (§3.C), sans réintroduire Deequ ni de dépendance Spark
Dépriorisation à long terme de Soda Core (feuille de route de l'éditeur orientée Soda Cloud)	Moyenne	Faible à moyen	Risque de trajectoire, pas de test ponctuel possible sur la durée du pilote : suivre l'évolution de la parité de fonctionnalités du noyau open source au-delà du pilote ; TestGen (§3.C) documenté comme repli si la dégradation se confirme, sous réserve de vérifier sa maturité d'écosystème avant bascule
Décalage de synchronisation entre Collibra et OpenMetadata	Faible	Moyen	Vérification au Jalon 09 ; calibration de la fréquence de synchronisation au regard des délais réglementaires (notification de violation sous 72h)
Seuils de classification par impact mal calibrés (§3.E)	Moyenne	Moyen	Mesurer le délai réel par palier au Jalon 13, resserrer ou desserrer les seuils avant généralisation plutôt que rouvrir le principe de proportionnalité lui-même
Résistance du département pilote au changement	Moyenne	Moyen	Voir §3.F.9
Désalignement avec les cycles budgétaires trimestriels lors des transitions inter-département (§3.G.2)	Moyenne	Moyen	Anticiper la demande d'allocation budgétaire de Phase 3 avant la clôture de Phase 2 plutôt qu'après ; si le cycle trimestriel ne coïncide pas, accepter un report ponctuel de la phase concernée plutôt que de forcer un déploiement sans budget validé
Déploiement initial de Collibra/RoPA plus long que prévu, retardant le jalon dépendant (test connecteur, Jalon 09)	Moyenne	Moyen	Fenêtre de configuration à redimensionner lors de la révision du calendrier du pilote ; prioriser la classification des données les plus sensibles avant population exhaustive du RoPA
Absence de classification préalable des données, condition de la population fiable du RoPA (§3.F.2, point 6)	Élevée	Moyen	Aucun dispositif formel de classification n'existe dans ce plan ; documenter la population du RoPA comme provisoire jusqu'à ce qu'un schéma de classification soit établi (hors périmètre du pilote actuel)

3.F.9 Formation et accompagnement au changement

Ce volet répond à **E6**, transversal à l'ensemble du pilote plutôt que rattaché à un outil particulier. Il cible en priorité le Data Steward et le Product Manager du périmètre pilote, qui expérimentent les premiers le mécanisme de double rattachement : une session de prise en main des outils (Collibra, OpenMetadata, Soda Core) et une clarification explicite de la répartition des responsabilités entre autorité fonctionnelle (CDO) et autorité organisationnelle (département) - point identifié comme source de confusion potentielle dès la conception de l'organigramme [D22].

3.F.10 Évaluation et retours d'expérience

Cette section consolide en un processus explicite les livrables individuels produits en §3.F.5, plutôt que de les laisser comme une simple liste de documents indépendants.

Méthode d'évaluation. Chaque livrable de §3.F.5 est confronté aux KPIs de §3.F.6 lors de la revue intermédiaire (Jalon 12) puis de la revue finale (Jalon 16, §3.F.4) : le rapport de qualité des données est comparé aux cibles de niveau de maturité DMAT ; le rapport de validation du circuit de classification et d'approbation IA est confronté au critère de délai fixé en §3.G.1 ; l'estimation d'Engineering overhead est comparée à l'hypothèse de charge initiale (§3.F.2, point 2).

Enseignements à documenter. Au-delà de la mesure quantitative, la revue finale (Jalon 16) produit une synthèse qualitative structurée autour de trois questions : ce qui a fonctionné mieux que prévu (à généraliser sans réserve), ce qui a nécessité un ajustement en cours de pilote (à surveiller lors de la généralisation), et ce qui reste non résolu (à traiter explicitement avant la phase 2, plutôt que reporté par défaut).

Recueil des retours des parties prenantes. Les retours du Data Steward, du Model Owner et du Data Owner (§3.F.3) sont recueillis de façon structurée lors de la revue finale, distincts des indicateurs quantitatifs - notamment sur le mécanisme de double rattachement (§3.F.1 ; indicateurs quantitatifs dédiés : §3.F.6) et sur la lisibilité du circuit de classification et d'approbation par niveau d'impact, deux points identifiés comme sources potentielles de friction dès la conception du plan.

Cette synthèse d'évaluation est le document d'entrée de la décision de généralisation (§3.G.1) : elle précède et alimente les critères de passage à l'échelle, plutôt que de leur être parallèle.

3.G. Feuille de route de généralisation détaillée

3.G.1 Conditions de passage à l'échelle

La généralisation n'est pas automatique : elle est conditionnée aux résultats du pilote sur chacun des points laissés ouverts en §3.F.2. Chaque outil ou mécanisme est soumis à une décision de type feu vert/orange/rouge, adossée aux KPIs de §3.F.6 et aux risques de §3.F.8.

Le pilote ne découvre plus s'il faut différencier le circuit d'approbation IA par niveau d'impact - ce principe de proportionnalité est posé dès la conception ([D21, §2.1.5]) - mais calibre les seuils quantitatifs (portée, réversibilité) qui déterminent le palier applicable à chaque modèle.

Dispositif testé	Critère de passage à l'échelle	Si échec / résultat mitigé
Double rattachement Data Steward (E1)	Absence de conflit d'autorité rapporté entre CDO et département sur la durée du pilote	Clarifier par écrit la répartition fonctionnel/organisationnel avant extension, plutôt que d'abandonner le mécanisme
Soda Core / module qualité OpenMetadata	Décision explicite prise au Jalon 08.1 sur le recouvrement	Généraliser uniquement l'outil retenu à l'issue du test
Connecteur Collibra/OpenMetadata	Synchronisation vérifiée au Jalon 09, fréquence jugée compatible avec les délais réglementaires (notification sous 72h)	Si insuffisant : resserrer la fréquence de synchronisation, ou évaluer une intégration complémentaire avant généralisation
Soda Core pour la qualité des données d'entraînement (E5)	Contrôles jugés suffisants entre les Jalons 08.1 et 11 face aux besoins réels du moteur de recommandation	Si insuffisant : bascule vers Cuallee (§3.C), sans réintroduire Deequ ni la dépendance Spark
Circuit de classification et d'approbation par niveau d'impact ([D21-Annexes, §2.1.A.3])	Délai d'approbation mesuré au Jalon 13 pour le palier concerné, jugé compatible avec le rythme de mise en production	Si le palier fort impact reste trop lent malgré la différenciation : resserrer les critères de classification pour réduire le nombre de modèles y basculant, plutôt que d'alléger le circuit lui-même
Déploiement incrémental Collibra/RoPA (E1, E3)	Configuration scopée PD jugée fonctionnelle et extensible sans reconstruction majeure	Si la configuration scopée est mal adaptée à l'extension : revoir l'architecture du glossaire/RoPA avant Phase 3 plutôt que de répliquer une structure défaillante
Engineering overhead Data Custodians	Estimation produite au Jalon 12 comparée à la capacité réelle de l'équipe Engineering	Si la charge est intenable : séquencer le déploiement des outils DC sur plusieurs trimestres plutôt qu'en parallèle
Phase de sécurisation (Jalons 01 à 06)	Franchissement du Jalon 06 sans suspension, avec délais de résolution documentés pour chaque point de vigilance rencontré	Si un point s'avère structurellement bloquant (absence d'annuaire central, notamment) : le traiter comme chantier séparé avant toute généralisation, pas seulement avant la Phase 2

3.G.2 Séquencement du déploiement aux autres périmètres

Le pilote ne couvre qu'un sous-ensemble des activités d'un seul département (Product Development, données d'entraînement du moteur de recommandation). Le reste des activités de PD, ainsi que les autres départements identifiés dans l'organigramme [D22], restent à couvrir.

Phase	Périmètre	Justification de l'ordre
Phase 1 (pilote)	*Product Development* - données d'entraînement des modèles de recommandation	Pilote (cf. §3.F)
Phase 2	*Product Development* - activités restantes (hors entraînement des modèles)	Complète le périmètre du département pilote en capitalisant sur l'équipe déjà formée (§3.F.9) et les outils déjà déployés (Collibra, OpenMetadata, Soda Core) - coût marginal faible, valide le mécanisme sur un périmètre de données plus large avant d'étendre à un département non formé. Choix assumé : ce séquencement retarde d'autant la couverture de Marketing, le périmètre le plus exposé au risque réglementaire (E3/E4)
Phase 3	*Marketing*	Concentre à la fois E1 (silos entre marketing et autres métiers, déjà documentés dans [R2]) et E3/E4 (données d'engagement publicitaire directement soumises au consentement RGPD/CCPA) - le périmètre le plus exposé au risque réglementaire
Phase 4	*Content Curation*	Couvre en priorité E2 et la gouvernance des métadonnées de contenu, restées en niveau 1 dans [D1] (dimensions Metadata et Master & Reference Data) sans la complexité IA déjà éprouvée en phase 1

Phase	Périmètre	Justification de l'ordre
Continu	*Engineering* (élargissement)	Les Data Custodians, déjà mobilisés dès la phase 1 comme opérateurs transverses, étendent progressivement le périmètre de Wazuh/OpenBao/OpenMetadata à l'ensemble des domaines au fil des phases

Chaque département nouvellement couvert dispose de son propre stockage préexistant, avec ses propres profils d'accès jamais centralisés - le même problème que celui traité pour Product Development en phase 1 (§3.D, proc. 1). Contrairement à la phase 1, cependant, cette extension n'a plus besoin de revalider l'ensemble de la phase de sécurisation (Jalons 01 à 06) : l'annuaire d'entreprise central, les rôles OpenBao et les intégrations SSO déjà validés sont étendus au nouveau périmètre plutôt que reconstruits - seule la migration propre au nouveau stockage (régénération des secrets, collecte des profils) doit être reconduite, sous une forme allégée. C'est ce qui justifie une **durée canonique de phase réduite** pour les phases 2 à 4 : 3 mois (12 semaines), contre 21 semaines pour la phase 1, qui seule porte le coût complet de la validation de sécurité.

L'intervalle entre phases est également renforcé, porté à **2 mois** (contre 1 mois initialement), pour mieux absorber le risque déjà identifié d'alignement sur des cycles budgétaires trimestriels (§3.F.8) lors des transitions vers un nouveau département - une marge plus généreuse que la précédente, au prix d'un calendrier global allongé :

Étape	Durée active	Intervalle avant la suivante	Fin cumulée
Phase 1 - Pilote (*Product Development* - entraînement recommandation & sécurisation complète)	21 semaines (~5 mois)	2 mois	M5
Phase 2 - *Product Development* - activités restantes	3 mois (12 semaines)	2 mois	M10
Phase 3 - *Marketing*	3 mois	2 mois	M15
Phase 4 - *Content Curation*	3 mois	-	M20
Consolidation vers niveau 3 (audits, mesure continue [D21, §2.1.7])	-	-	M22-M24

Le séquencement proposé consomme la totalité du budget de référence donné en [R1, Q7] (pilote 3-6 mois, déploiement complet +12-18 mois, soit 15-24 mois au total). C'est le surcoût cumulé, et incompressible, de la phase de sécurisation préliminaire et des marges renforcées inter-phases .

3.G.3 Ajustements attendus au cadre de gouvernance

La feuille de route prévoit explicitement que la politique [D21] et l'organigramme [D22] puissent être révisés à l'issue de la phase 1, conformément au principe d'amélioration continue déjà posé en P9 [D21, §2.1.7]. Diverses ajustements devront être confirmés ou infirmés à l'issue du pilote :

- *Calibration* finale des seuils de classification des niveaux d'impact (portée, réversibilité) selon les résultats du pilote.
- *Révision* du tableau d'outils [D3, §3.4] sur les deux lignes explicitement testées en pilote (recouvrement *Soda Core* / *OpenMetadata*, suffisance de *Soda Core* pour E5), qui ne doivent pas être considérées comme définitives avant la fin de la phase 1.
- *Établissement* d'un coût total de possession (infrastructure, maintenance pluriannuelle) pour les outils opérés par les *Data Custodians* - au-delà de l'*engineering overhead*, mesuré par ailleurs en phase en pilote (§3.F.2) - une fois qu'un historique d'exploitation suffisant sera disponible.
- *Validation* de la couverture *DSAR* par *TrustArc* (retirée du périmètre du pilote car sans lien avec le périmètre des modèles et les données d'entraînement retenu). Cette validation devra être conduite comme exercice séparé, porté par *DPO*/*Legal Team*, avant l'ouverture de la phase 3 (*Marketing*) où E3/E4 deviennent le risque dominant (§3.G.2). Elle pourra s'appuyer sur le RoPA déjà peuplé en pilote (§3.F.2, point 5), sous réserve que la classification préalable des données (point 6) ait été établie d'ici là.
- *Documentation* de l'extension de sécurisation (régénération des secrets, collecte des profils) requise à chaque nouveau département (ne pas confondre avec la phase de sécurisation complète de la phase 1 (§3.D, processus 01 à 06)).

3.G.4 Trajectoire de maturité à moyen terme

Échéance	Étape	Niveau de maturité visé [D1] / [R1]	Position par rapport au budget de référence [R11, Q7]
M5	Pilote clos, décisions go/no-go	*Niveau 2* sur le périmètre pilote (Data Governance, Data Quality)	Borne haute de la fourchette pilote (3-6 mois) - prend en compte la phase de sécurisation intégrée
M10	*Product Development* couvert dans son ensemble	*Niveau 2-3* sur Data Governance et Data Quality, étendu à tout le périmètre *Product Development*	Dans la fenêtre de déploiement (+12-18 mois)
M15	*Marketing* couvert	*Niveau 2-3* sur Compliance et Data Usage & Accessibility	Dans la fenêtre de déploiement (+12-18 mois)
M20	*Content Curation* couvert, *Engineering* élargi	*Niveau 3* sur Metadata et Master & Reference Data	Approche la borne haute du déploiement complet
M22-M24	Ensemble des départements couverts	*Niveau 3* sur l'ensemble des dimensions actuellement en niveau 1, conformément à l'objectif fixé en [D21, §2.1.7]	Borne haute de la fourchette de déploiement complet (15-24 mois)

Cette trajectoire reste indicative : chaque jalon de phase est un point de réévaluation, pas un engagement figé - la feuille de route est elle-même soumise au principe d'amélioration continue qu'elle sert à mettre en œuvre. Le calendrier global (22 à 24 mois du lancement du pilote à la consolidation) atteint désormais la borne haute de la fourchette de référence [R11, Q7], avec des paliers de décision renforcés à 2 mois entre phases - un arbitrage qui privilégie la marge de sécurité contre le risque de retard [R11, Q11] au prix d'un calendrier plus long.

Références

Livrables

- [D1] *Data Maturity Assessment Report*
- [D21] *Data Governance Policy Document*
- [D22] *Organizational Chart*
- [D3] *Implementation Plan*

Annexes

- [D1-Annexes] *Data Maturity Assessment Report's Annexes*
- [D21-Annexes] *Data Governance Policy Document's Annexes*
- [D22-Annexes] *Organizational Chart's Annexes*

Ressources

- [R1] Australian Government Data Maturity Assessment Tool (2026)
- [R2] Spotify Business Case
- [R7] Organizational Models Overview
- [R8] Tech Tools Overview
- [R11] Executive Q&A Guide